

Amoura — Feuille de route des améliorations

Plan d'amélioration continue de la plateforme Version : 2.1 · Date : 27 juillet 2026 · Portée : améliorations livrées + backlog priorisé

Légende — **Impact** : ● Faible · ● Moyen · ● Élevé | **Effort** : S (≤2 j) · M (≤1 sem) · L (2-3 sem) · XL (>1 mois) | **Priorité** : P0 (critique) → P3 (confort)

1. Améliorations livrées dans cette itération

Ces améliorations issues des Phases 1 & 2 de la feuille de route produit ont été **implémentées et testées** (suite passée à **164 tests / 435 assertions**, analyse statique **PHPStan niveau 5 sans erreur**).

Amélioration	Axe	Détail	Vérification
Recommandations par affinité	Produit / UX	<code>Services\Recommender</code> classe la découverte : intérêts partagés, proximité (distance ou ville/pays), proximité d'âge, présence en ligne, activité récente, badge vérifié.	7 tests unitaires + 1 test d'intégration
Purge planifiée (cron)	Fiabilité	<code>Services\Maintenance</code> + <code>scripts/cron.php</code> : suppression des statuts expirés, jetons OTP, sessions, rate-limits, notifications & messages anciens.	1 test d'intégration (purge sélective)
Journalisation structurée	Observabilité	<code>Services\Logger</code> écrit des lignes JSON exploitables (ELK/Loki) ; branché sur le gestionnaire d'erreurs global et le cron.	2 tests unitaires
PWA installable + hors-ligne	UX / Mobile	<code>manifest.webmanifest</code> , <code>service-worker.js</code> (cache-first assets, network-first API, repli <code>offline.html</code>), icônes 192/512, enregistrement auto.	Smoke test HTTP (200 sur tous les fichiers)
Serveur de dev correct	DevEx	<code>server.php</code> sert les fichiers statiques + PWA en développement (les assets ne partaient plus en 404 hors Apache).	Smoke test (assets 200)
CI/CD (GitHub Actions)	DevEx	<code>.github/workflows/amoura-ci.yml</code> : lint PHP + tests unitaires & d'intégration (service MySQL) à chaque push/PR.	Workflow validé (yaml + étapes)
Index & requêtes optimisés	Performance	Nouveaux index composites (matches, swipes, stories, posts) + réécriture <code>forUser</code> en UNION (2 lookups indexés au lieu d'un scan). Vérifié via <code>EXPLAIN</code> .	EXPLAIN + tests d'intégration
Migrations versionnées	DevEx	<code>database/migrations/</code> + runner (<code>migrate</code> / <code>--fresh</code> baseline / <code>status</code>) suivi dans <code>schema_migrations</code> .	Testé (fresh + BDD existante)
Signature webhook PayPal	Sécurité	<code>verifyWebhookSignature</code> via l'API <code>/v1/notifications/verify-webhook-signature</code> (fail-closed).	1 test unit + 2 intégration
CSP par nonce	Sécurité	Suppression de <code>'unsafe-inline'</code> (scripts) : nonce par requête + délégation d'événements (<code>ui.js</code> , 17 handlers migrés).	Smoke test (nonce en-tête = balises)
« Qui a vu mon profil »	UX / Monétisation	Table <code>profile_views</code> , suivi des visites, page <code>/visitors</code> (liste floutée hors Premium).	3 tests d'intégration
i18n FR/EN	UX	<code>Core\I18n</code> + fichiers de langue + helper <code>t()</code> + détection cookie/Accept-Language + sélecteur de langue ; nav/accueil/connexion traduits.	5 tests unitaires

Amélioration	Axe	Détail	Vérification
Onboarding guidé	UX	Carte de complétion de profil (étapes cochables) sur la découverte tant que < 100 %.	Smoke test (rendu)
Notifications Web Push	UX / Engagement	VAPID + abonnements (<code>push_subscriptions</code>), service worker (<code>push / notificationclick</code>), <code>PushService</code> (dégradation gracieuse), câblé aux messages.	1 intégration + envoi vérifié
Cache Redis	Performance / Scale	Abstraction <code>Core\Cache</code> (Redis + repli mémoire), réglages CMS mis en cache, sessions partagées (handler Redis), rate-limiter distribué (INCR atomique).	5 unit + 3 intégration (Redis réel)
Clustering WebSocket	Scale	Bus pub/sub (<code>websocket/Bus</code> : Redis via clue/redis-react + repli local mono-instance) ; le serveur relaie les messages entre instances.	Boot vérifié (local + Redis)
Modération IA v1	Confiance	<code>Services\Moderation\ContentModerator</code> (interface <code>Moderator</code> échangeable) : coordonnées, arnaques, harcèlement, sollicitation, spam → score + action ; publications à risque bloquées ou mises en file de revue.	8 unit + 2 intégration + E2E
2FA (TOTP)	Sécurité	<code>Core\Security\Totp</code> conforme RFC 6238 (Google Authenticator/Authy) : configuration, activation, connexion en deux étapes, désactivation par mot de passe.	7 unit + 1 intégration + E2E
Révocation de sessions	Sécurité	« Déconnecter partout » via <code>sessions_valid_after</code> (comparaison stricte) ; la session courante est préservée.	2 intégration + E2E (2 sessions)
Achats à l'unité	Monétisation	Catalogue <code>products</code> + portefeuille <code>user_credits</code> (débit atomique) ; Boost (ordre de découverte), Super Like (gating), Reveal (déblocage 24 h). Paiement → <code>Fulfillment</code> crédite (idempotent).	3 intégration + E2E
Dunning (relances)	Monétisation	<code>Services\Billing\Dunning</code> (cron) : rappel J-3 → <code>past_due</code> à l'échéance → <code>expired</code> après grâce, avec notifications.	4 tests d'intégration

1.1 Itération de durcissement (Sprint +6) ✓

Dernière itération : **tout le reliquat du backlog** a été traité.

Amélioration	Axe	Détail	Vérification
Chiffrement des messages au repos	Sécurité	<code>Core\Security\Crypto</code> (libsodium secretbox, clé dérivée d' <code>APP_KEY</code>) : <code>Message::send()</code> chiffre le corps, <code>history()</code> déchiffre ; rétro-compatible (texte clair renvoyé tel quel), dégradation gracieuse sans l'extension.	4 unit + 1 intégration (chiffré en base, clair via l'API)
Détection d'appareils	Sécurité	<code>Services\Security\DeviceMonitor</code> : empreinte (UA + préfixe réseau /24-/48), table <code>login_devices</code> , alerte de connexion depuis un nouvel appareil.	1 test d'intégration (2 ^e appareil = 1 alerte)
Réplicas de lecture	Scale	<code>Database::read()</code> (réplica <code>DB_READ_*</code> , repli automatique sur le primaire).	Config <code>.env</code> + repli vérifié
CDN + stockage objet S3	Scale	Abstraction <code>Core\Storage</code> (<code>LocalStorage</code> défaut, <code>S3Storage</code> SigV4, <code>StorageManager</code> piloté par <code>STORAGE_DRIVER</code>), URLs CDN.	5 tests unitaires (local, anti-traversée)
Pagination par curseur	Performance	<code>Core\Paginator</code> (curseur opaque base64url keyset) ; notifications & historique migrés depuis <code>OFFSET</code> .	4 tests unitaires

Amélioration	Axe	Détail	Vérification
Réponses citées & éphémères	UX	<code>messages.reply_to_id</code> (réponse citée déchiffrée) + <code>expires_at</code> (TTL, exclus après expiration, purgés par le cron).	2 tests d'intégration
Filtres de style de vie	UX	<code>profiles</code> : tabac, alcool, enfants, religion, objectif de relation ; filtres de découverte + édition de profil.	Intégration matching
Anti-fraude (score de risque)	Confiance	<code>Services\Moderation\RiskScorer</code> : âge du compte, photo, signalements, coordonnées/arnaque en bio, vitesse, remise si vérifié → score 0-100 + niveau.	5 tests unitaires
File de modération priorisée + actions groupées	Confiance	<code>Report::queue()</code> triée par sévérité (mineurs → arnaque → ...) + <code>bulkResolve()</code> ; UI admin (cases à cocher, actions en masse).	2 tests d'intégration
Reçus de paiement	Monétisation	Historique de facturation (<code>/premium/history</code>) + reçu imprimable/PDF (<code>/premium/receipt/{id}</code> , portée utilisateur, transactions payées uniquement).	1 test d'intégration (portée) + smoke rendu
Coupons & offres	Monétisation	<code>Models\Coupon</code> (% ou montant, plafond de rachats, expiration, rachat atomique) intégré au tunnel d'abonnement.	1 unit + 2 intégration
Analyse statique (PHPStan)	DevEx	<code>phpstan.neon</code> niveau 5 (app/scripts/websocket), script <code>composer stan</code> , 0 erreur (corrections de types réelles au passage).	CI-ready
Documentation API (OpenAPI)	DevEx	<code>docs/openapi.yaml</code> (OpenAPI 3.0.3) : découverte, swipe, messagerie chiffrée, notifications, push, webhooks.	Spéc validée

1.2 Mise en production — Phase 1, lot 1 (Sprint +7)

Amélioration	Axe	Détail	Vérification
File d'envoi e-mail/SMS asynchrone	Fiabilité / Scale	Table <code>message_outbox</code> + <code>Models\Outbox</code> (réclamation par lot <code>FOR UPDATE SKIP LOCKED</code> , relances à backoff exponentiel , lettre morte) ; <code>Messaging\Dispatcher</code> (modes <code>sync</code> / <code>async</code>) ; <code>scripts/worker.php</code> (démon + <code>--once</code>) ; drain intégré au cron. Découple la latence prestataire du temps de réponse HTTP.	6 tests d'intégration (file, drain, backoff, lettre morte)
Passerelle SMS réelle	Infrastructure	<code>Services\Sms</code> : interface <code>SmsGateway</code> , <code>LogSmsGateway</code> (dev), <code>HttpSmsGateway</code> (REST générique, bearer, réf. prestataire), <code>SmsManager</code> piloté par <code>SMS_DRIVER</code> . <code>Mailer::send</code> route désormais via la file.	3 tests unitaires
Exemple Nginx <code>wss://</code> + TLS	Déploiement	<code>deploy/nginx.sample.conf</code> : terminaison TLS, HSTS, cache assets, proxy WebSocket sécurisé ; service worker ajouté au <code>docker-compose</code> .	Config fournie
Sauvegarde MySQL	Fiabilité	<code>scripts/backup.sh</code> : <code>mysqldump --single-transaction</code> , compression, rotation configurable.	Syntaxe validée
Checklist OWASP Top 10	Sécurité	<code>docs/SECURITE_OWASP.md</code> : revue A01-A10 mappée au code + contrôles de lancement.	Document de revue

2. Backlog d'améliorations priorisé

2.1 Sécurité & conformité

Amélioration	Impact	Effort	Priorité
~~Nonces CSP + suppression des handlers inline~~	●	L	✅ Livré
~~Vérification de signature webhook PayPal~~	●	M	✅ Livré
~~Authentification à deux facteurs (2FA) optionnelle~~	●	M	✅ Livré
~~Rotation & révocation de sessions (« déconnecter partout »)~~	●	S	✅ Livré
~~Chiffrement au repos des messages sensibles~~	●	L	✅ Livré
~~Détection d'appareils & alertes de connexion suspecte~~	●	M	✅ Livré

2.2 ⚡ Performance & passage à l'échelle

Amélioration	Impact	Effort	Priorité
~~Cache Redis (sessions, rate-limit, réglages CMS)~~	●	M	✅ Livré
~~Index composites & EXPLAIN sur découverte / fil / messages~~	●	S	✅ Livré
~~Répliques de lecture MySQL (séparation lecture/écriture)~~	●	L	✅ Livré
~~Clustering WebSocket (Redis pub/sub)~~	●	L	✅ Livré
~~CDN + stockage objet (S3) pour médias~~ (<i>transcodage vocal à venir</i>)	●	L	✅ Livré
~~Pagination par curseur généralisée (au lieu d' OFFSET)~~	●	M	✅ Livré

2.3 🧑‍💻 Expérience utilisateur

Amélioration	Impact	Effort	Priorité
~~Notifications Web Push~~	●	M	✅ Livré
~~Internationalisation (i18n) FR/EN + sélecteur~~	●	M	✅ Livré
~~Onboarding guidé + complétion de profil~~	●	M	✅ Livré
~~« Qui a vu mon profil » + derniers visiteurs~~	●	S	✅ Livré
~~Réponses citées & messages éphémères dans le chat~~	●	S	✅ Livré
~~Filtres de découverte enrichis (style de vie, valeurs)~~	●	S	✅ Livré
Skeletons/optimistic UI systématiques	●	S	P3

2.4 🛡️ Confiance & modération

Amélioration	Impact	Effort	Priorité
Modération assistée par IA (nudité, arnaque, mineurs) — <i>v1 heuristique</i> ✅ ; ML/API à venir	●	L	P2
Vérification selfie semi-automatique (liveness) (<i>file de demandes livrée ; liveness ML à venir</i>)	●	L	P1
~~Anti-fraude : score de risque des profils & signaux~~	●	L	✅ Livré
~~File de modération priorisée + actions groupées~~	●	S	✅ Livré

2.5 🛠️ Qualité & industrialisation (DevEx)

Amélioration	Impact	Effort	Priorité
~~CI/CD (lint + tests) via GitHub Actions~~	●	S	✓ Livré
~~Migrations de schéma versionnées~~	●	M	✓ Livré
Couverture de tests > 70 % (121 tests ; contrôleurs/WebSocket à renforcer)	●	M	P1
~~Analyse statique (PHPStan niveau 5)~~ (PHP-CS-Fixer à venir)	●	S	✓ Livré
~~Documentation API OpenAPI~~ (collection de tests à venir)	●	M	✓ Livré
Environnement de préproduction (staging) automatisé	●	M	P2

2.6 🇪🇺 Monétisation

Amélioration	Impact	Effort	Priorité
~~Achats à l'unité (Boost, Super Like, révéler admirateurs)~~	●	M	✓ Livré
~~Relances d'échec de paiement (dunning)~~ + renouvellement auto (état + notifs livrés ; recharge prestataire à venir)	●	M	✓ Livré
~~Facturation/reçus (imprimable/PDF)~~ (portefeuille de crédits déjà livré)	●	M	✓ Livré
~~Coupons & offres~~ (essais gratuits à venir)	●	S	✓ Livré

3. Matrice impact / effort

✂ Quick wins (fort impact, faible effort) — à faire en priorité :

- Index composites + EXPLAIN sur les requêtes chaudes (P0).
- CI/CD GitHub Actions (P0).
- Révocation de sessions « déconnecter partout » (P1).
- « Qui a vu mon profil » (P2).

🔧 Grands chantiers (fort impact, fort effort) — à planifier :

- Nonces CSP, cache Redis, clustering WebSocket.
- Modération IA, vérification liveness, anti-fraude.

🔪 À intégrer au fil de l'eau (faible effort) : skeletons, réponses citées, coupons.

4. Prochaines itérations recommandées

Sprint	Thème	Contenu clé
Sprint +1 ✓	Socle production	CI/CD · index & EXPLAIN · nonces CSP · signature webhook PayPal — livré
Sprint +2 ✓	Engagement	Web Push · i18n FR/EN · onboarding · « qui a vu mon profil » — livré
Sprint +3 ✓	Scale & confiance	Cache Redis · clustering WebSocket · modération IA (v1) — livré

Sprint	Thème	Contenu clé
Sprint +4 ✓	Sécurité des comptes	2FA (TOTP) · révocation de sessions — <i>livré</i>
Sprint +5 ✓	Monétisation	Achats à l'unité (Boost/Super Like/Reveal) · dunning — <i>livré</i>
Sprint +6 ✓	Durcissement (reliquat backlog)	Chiffrement des messages · détection d'appareils · réplicas de lecture · stockage S3/CDN · pagination par curseur · réponses citées/éphémères · filtres style de vie · anti-fraude · file de modération priorisée · reçus · coupons · PHPStan · OpenAPI — <i>livré</i>
Sprint +7 ✓	Mise en production (Phase 1, lot 1)	File d'envoi e-mail/SMS asynchrone (outbox + worker, relances backoff) · passerelle SMS réelle (driver HTTP) · exemple Nginx <code>wss://</code> · script de sauvegarde MySQL · checklist OWASP — <i>livré</i>
Sprint +8 ✓	Mise en production (Phase 1, lot 2)	Tests de charge HTTP & WebSocket + budget de performance (CI) · briques <code>Benchmark</code> / <code>Realtime</code> testées · correction d'un crash du serveur WS à la connexion (<code>parse_url</code> sur objet PSR-7) — <i>livré</i>
Sprint +9 ✓	Confiance & conformité (Phase 4, lot 1)	RGPD : consentements granulaires (<code>user_consent</code>) · export complet (accès/portabilité) & effacement (droit à l'oubli) <code>Services\Gdpr</code> · centre de sécurité (appareils, consentements) · registre de traitement <code>docs/RGPD.md</code> — <i>livré</i>
Sprint +10 ✓	Confiance & conformité (Phase 4, lot 2)	Vérification de profil par selfie : soumission membre + pré-analyse heuristique (<code>Services\Verification</code> , interface liveness pluggable) · file de revue admin (score auto, approbation → badge, rejet) · notifications — <i>livré</i>
Sprint +11 ✓	Monétisation — finitions (Phase 3)	Mode incognito (navigation privée VIP, gated) · tableau de bord revenus admin (MRR, ARPU, LTV, churn, tendance 12 mois, répartition prestataire/offre, graphe SVG sans script) — <i>livré</i>

5. Indicateurs de suivi des améliorations

- **Performance** : p95 des temps de réponse API, latence WebSocket, temps de requête découverte.
- **Fiabilité** : taux d'erreur 5xx, volume purgé/jour, disponibilité (uptime).
- **Qualité** : couverture de tests, nombre de tests, alertes d'analyse statique.
- **Engagement** : taux d'installation PWA, opt-in Web Push, CTR des recommandations.
- **Sécurité** : incidents, délai de correctif, comptes frauduleux bloqués.